

Identity & Access Management Implementation

Cloud Security 1 — Rubric Evidence & Documentation

Project: AccessGuard Health

Scenario: Horizon Valley Medical Center (HVMC) — Simulated Healthcare EHR Environment

Platform: Microsoft Azure & Microsoft Entra ID

Rubric Requirement

“The project must demonstrate IAM configuration and identity federation setup. Students must configure IAM policies, users, groups, and roles with least privilege principles and multi-factor authentication in AWS, Azure, or GCP with screenshots. Advanced implementation must include creating custom IAM policies using JSON, implementing ABAC using resource tags, and setting up SAML federation with documentation of the complete federation workflow and evidence of successful authentication testing.”

Summary of Completion

Rubric Item	Status
Test identity (user) created in Microsoft Entra ID	Complete
Least-privilege role assignment (built-in RBAC role)	Complete
Multi-Factor Authentication (MFA) configured	Complete
Verification testing: read allowed / write denied	Complete
Advanced: Custom IAM policy using JSON	Complete
Advanced: ABAC using resource tags	Complete
Advanced: SAML federation with workflow + auth test evidence	Not yet complete (see Section 8)

This document walks through each rubric requirement in order, with the corresponding Azure Portal screenshots captured during implementation as evidence.

1. Environment & Scope

All IAM configuration was performed against a live Azure subscription, using Microsoft Entra ID (the Azure tenant's identity provider) and an Azure Storage account (**hvmcehrstorage**) representing a simulated Electronic Health Record (EHR) data store for Horizon Valley Medical Center. A dedicated, non-production test identity was created to demonstrate least-privilege access controls without using an administrator or production account for testing.

2. Test Identity Creation (Microsoft Entra ID)

A dedicated test user, **Test Nurse - EHR** (test-nurse-ehr), was created in Microsoft Entra ID to represent a nurse role that should have read-only access to EHR blob data, and nothing more. Using a separate identity rather than the administrator account allows every subsequent access test to reflect exactly what that role can and cannot do.

Home > Default Directory | Users > Users

Create new user

Create a new internal user in your organization

Basics Properties Assignments Review + create

Create a new user in your organization. This user will have a user name like alice@contoso.com. [Learn more](#)

Identity

User principal name *

test-nurse-ehr @

sabithaskaranavargmail.onmicrosoft.com

Domain not listed? [Learn more](#)

Mail nickname *

test-nurse-ehr

☒ Derive from user principal name

Display name *

Test Nurse - EHR

Password *

.....

☒ Auto-generate password

Account enabled ☒

[Review + create](#) [< Previous](#) [Next: Properties >](#)

Figure 2.1 — Creating the test user in Microsoft Entra ID (New user wizard).

Home

Test Nurse - EHR

User

Search

Edit propertiesDeleteRefreshReset passwordRevoke sessionsManage viewGot feedback?

Overview

Audit logs

Sign-in logs

Diagnose and solve problems

Custom security attributes

Assigned roles

Administrative units

Groups

Applications

Licenses

Devices

Azure role assignments

Authentication methods

Support + Troubleshooting

Basic info

TE

Test Nurse - EHR

test-nurse-ehr@sabithaskaranavargmail.onmicrosoft.com

Member

User principal name

test-nurse-ehr@sabithaskaranavargmail.onmicrosoft.com

Group memberships

0

Object ID

def0ae6f-5266-45a5-9144-0fd0cf076be8

Applications

0

Created date time

Sep 23, 2026, 11:47 AM

Assigned roles

0

User type

Member

Assigned licenses

0

Sign-in identifiers

[View](#)

My Feed

Account status

Enabled

Edit

B2B invitation

[Convert to external user](#)

Figure 2.2 — Test Nurse - EHR user successfully created and enabled in the directory.

3. Least-Privilege Role Assignment (Built-in RBAC)

Before building a custom policy, a built-in Azure RBAC role — **Storage Blob Data Reader** — was assigned to Test Nurse - EHR, scoped only to the hvmcehrstorage storage account. This role grants read-only access to blob data and nothing else (no write, delete, or account configuration rights), which is the Azure equivalent of a least-privilege IAM policy.

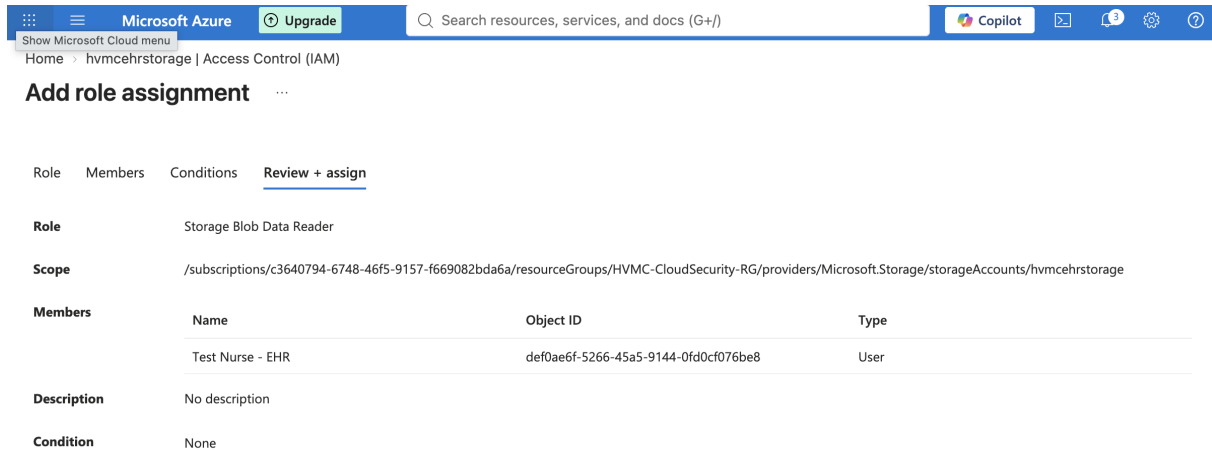


Figure 3.1 — Storage Blob Data Reader assigned to Test Nurse - EHR, scoped to hvmcehrstorage.

4. Multi-Factor Authentication (MFA)

Multi-factor authentication was configured for the Test Nurse - EHR identity in Microsoft Entra ID. The account initially had no authentication methods registered beyond a password; a second factor (Microsoft Authenticator, plus a backup Email method) was then registered, and the system-preferred MFA method was confirmed as enabled.

Microsoft Azure Upgrade Search resources, services, and docs (G+/)

Home > Default Directory | Users > Users > Test Nurse - EHR

Test Nurse - EHR | Authentication methods

User

Search x < + Add authentication method | Reset password | Require re-register multifactor authentication | Revoke sessions | View authentication methods policy | ...

- Overview
- Audit logs
- Sign-in logs
- Diagnose and solve problems
- Custom security attributes
- Assigned roles
- Administrative units
- Groups
- Applications
- Licenses
- Devices
- Azure role assignments
- Authentication methods**
- Support + Troubleshooting

The Revoke multifactor authentication sessions control has been updated. Learn more at <https://aka.ms/RevokeSessions>.

Authentication methods are the ways users sign into Microsoft Entra ID and perform self-service password reset (SSPR). The user's "default sign-in method" is the first one shown to the user when they are required to authenticate with a second factor - the user always can choose another registered, enabled authentication method to authenticate with. [Learn more](#)

Default sign-in method (Preview) No default

Usable authentication methods

Authentication method	Detail
No usable methods.	

Non-usable authentication methods

Authentication method	Detail
No non-usable methods.	

System preferred multifactor authentication method

Feature status	System preferred MFA method
Enabled	No system preferred MFA method

Figure 4.1 — Before: Test Nurse - EHR had no MFA method registered.

Microsoft Azure Upgrade Search resources, services, and docs (G+/)

Home > Default Directory | Users > Users > Test Nurse - EHR

Test Nurse - EHR | Authentication methods

User

Search x < + Add authentication method | Reset password | Require re-register multifactor authentication | Revoke sessions | View authentication methods policy | ...

- Overview
- Audit logs
- Sign-in logs
- Diagnose and solve problems
- Custom security attributes
- Assigned roles
- Administrative units
- Groups
- Applications
- Licenses
- Devices
- Azure role assignments
- Authentication methods**
- Support + Troubleshooting

The Revoke multifactor authentication sessions control has been updated. Learn more at <https://aka.ms/RevokeSessions>.

Authentication methods are the ways users sign into Microsoft Entra ID and perform self-service password reset (SSPR). The user's "default sign-in method" is the first one shown to the user when they are required to authenticate with a second factor - the user always can choose another registered, enabled authentication method to authenticate with. [Learn more](#)

Default sign-in method (Preview) Microsoft Authenticator notification

Usable authentication methods

Authentication method	Detail
Email	testnurseEHR@gmail.com ...
Microsoft Authenticator	iPhone 12 Pro ...

Non-usable authentication methods

Authentication method	Detail
No non-usable methods.	

System preferred multifactor authentication method

Feature status	System preferred MFA method
Enabled	PhoneAppNotification

Figure 4.2 — After: Microsoft Authenticator and Email registered; system-preferred MFA method shows Enabled (PhoneAppNotification).

5. Advanced: Custom IAM Policy Using JSON

To move beyond the built-in role and demonstrate a purpose-built least-privilege policy, a **custom Azure RBAC role** was authored directly in JSON — the Azure equivalent of a custom IAM policy document. The role, named **HVMC-Nurse-EHR-ReadOnly**, grants only the specific management-plane and data-plane read actions a nurse identity needs (list/read the storage account, list blob services and containers, and read blob data) and nothing else — no write, delete, or configuration actions are included.

Custom role creation is not available at the individual storage-account level in Azure; it must be created from a higher scope (the resource group, management group, or subscription). The role was created at the HVMC-CloudSecurity-RG resource group scope, with its *assignableScopes* restricted specifically to the hvmcehrstorage storage account.

5.1 — Correcting a schema error

The first JSON submission failed validation because the actions/dataActions were placed directly under *properties* instead of being nested inside a *permissions* array, which Azure's custom-role schema requires.

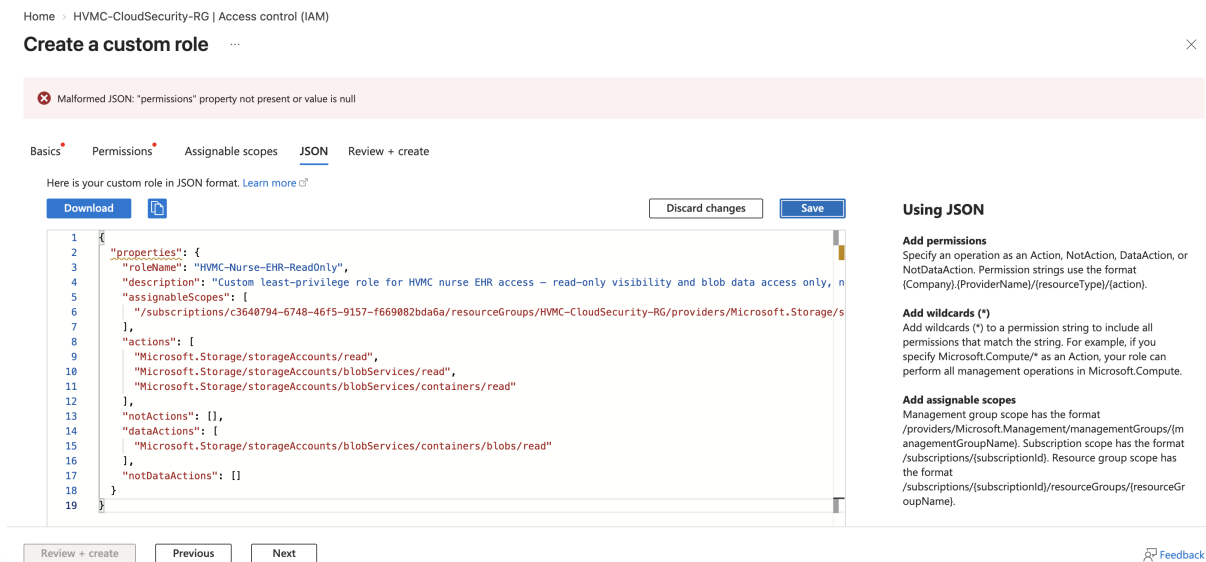


Figure 5.1 — Malformed JSON error: “permissions’ property not present or value is null.”

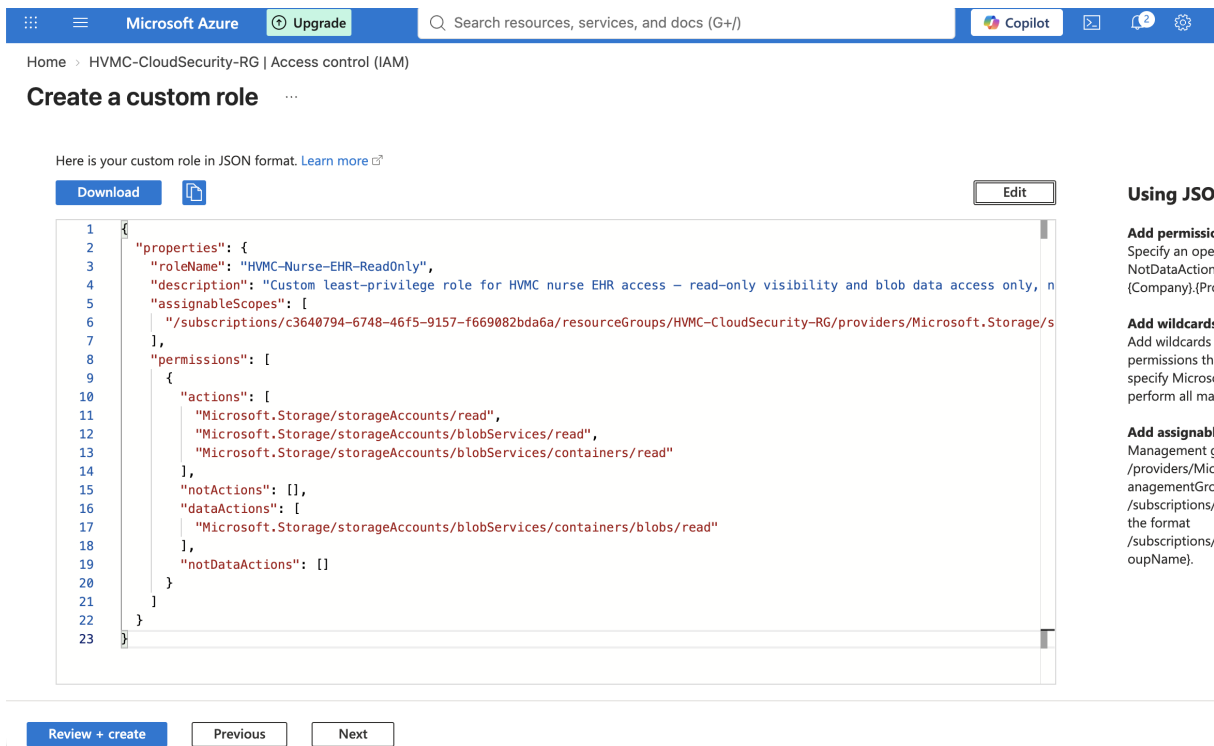


Figure 5.2 — Corrected JSON, with actions/dataActions properly nested inside a permissions array.

5.2 — Role creation and assignment

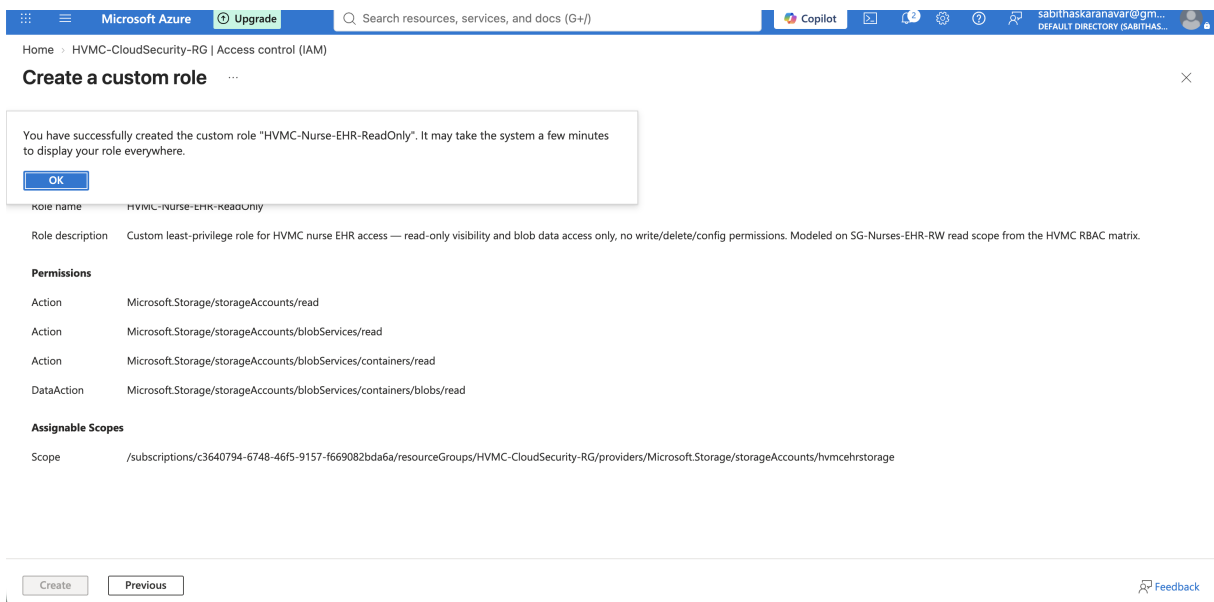


Figure 5.3 — Confirmation: custom role "HVMC-Nurse-EHR-ReadOnly" created successfully.

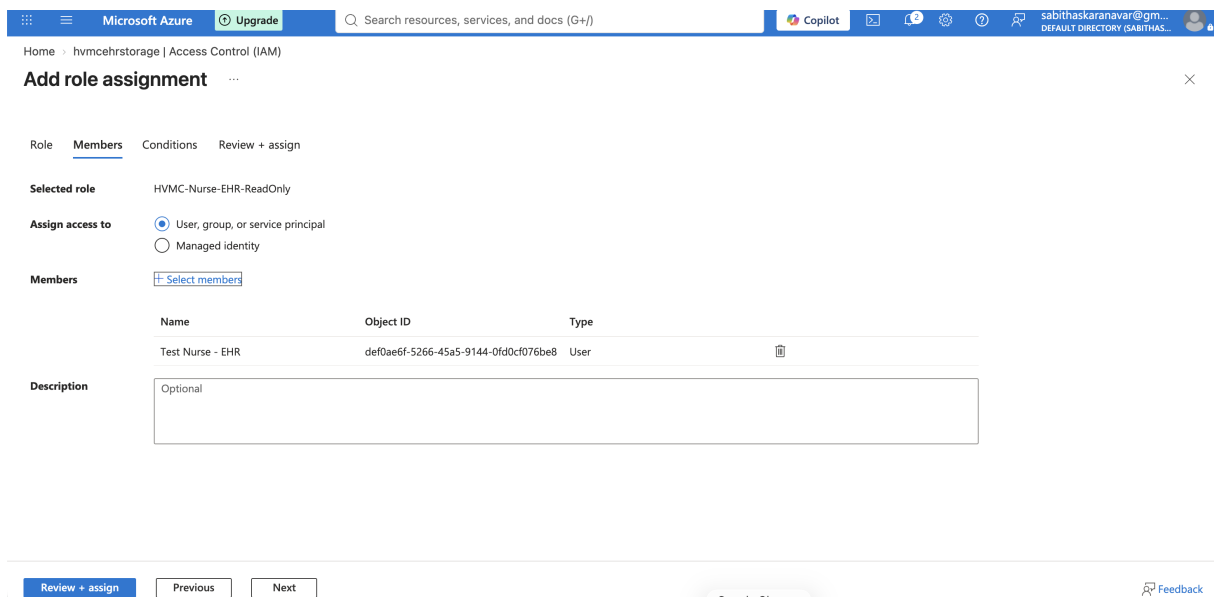


Figure 5.4 — Assigning the new custom role to Test Nurse - EHR.

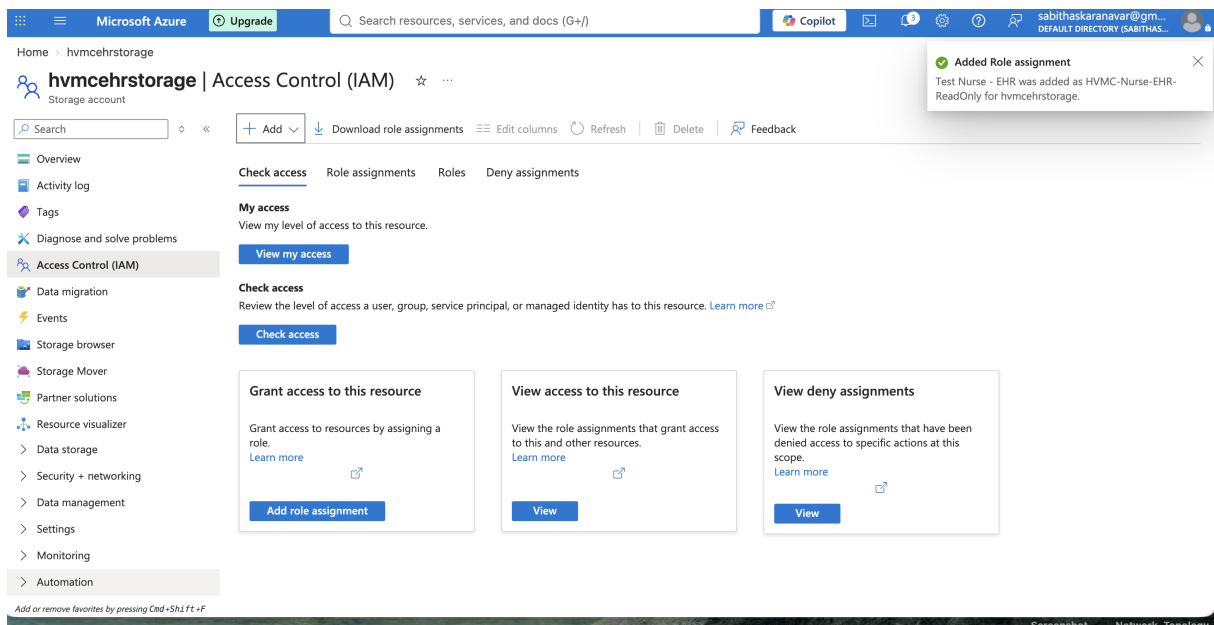


Figure 5.5 — Confirmation: role assignment added.

Once the custom role was verified to work independently (see Section 7), the earlier built-in role assignments (Reader and Storage Blob Data Reader) were removed, leaving the purpose-built custom role as the sole grant — consolidating least-privilege access into one auditable, self-documenting policy.

Microsoft Azure | Upgrade | Search resources, services, and docs (G+)

Home > hvmcehrstorage | Access Control (IAM) ☆ ...

Storage account

Search [] Add Download role assignments Edit columns Refresh Delete Feedback

Overview
Activity log
Tags
Diagnose and solve problems
Access Control (IAM)
Data migration
Events
Storage browser
Storage Mover
Partner solutions
Resource visualizer
Data storage
Security + networking
Data management
Settings
Monitoring
Automation
Help

Check access **Role assignments** Roles Deny assignments

Number of role assignments for this subscription ⓘ
2 5000

Search by name or email Type: All Role: All Scope: All scopes Group by: Role

All (2) Job function roles (1) Privileged administrator roles (1)

☐	Name ↑↓	Type ↑↓	Role ↑↓	Scope ↑↓	Condition ↑↓
✓	Owner (1)				
☐	Sabitha S Karanavar da18a0fd-30f0-419d-9f93-fb...	User	Owner	Subscription (Inherited)	None
✓	HVMC-Nurse-EHR-ReadOnly (1)				
☐	Test Nurse - EHR def0ae6f-5266-45a5-9144-0f...	User	HVMC-Nurse-EHR-ReadOnly	This resource	Add

Showing 1 - 2 of 2 results.

Removed Role assignment(s).
2 role assignments were removed from
/subscriptions/c3640794-6748-46f5-9157-
f669082bda6a/resourceGroups/HVMC-CloudSecurity-
RG/providers/Microsoft.Storage/storageAccounts/hvm...
Download deleted role assignments

Figure 5.6 — Redundant built-in role assignments removed; only Owner (admin) and HVMC-Nurse-EHR-ReadOnly remain.

6. Advanced: ABAC Using Resource Tags

Attribute-Based Access Control (ABAC) was implemented on top of the custom role using **Azure Blob index tags** — key/value metadata attached to individual files, functionally equivalent to AWS S3 object tags. Two files were uploaded into the same container (ehr-records) with different Department tags:

nursing-note.txt (Department = Nursing) and **finance-report.txt** (Department = Finance).

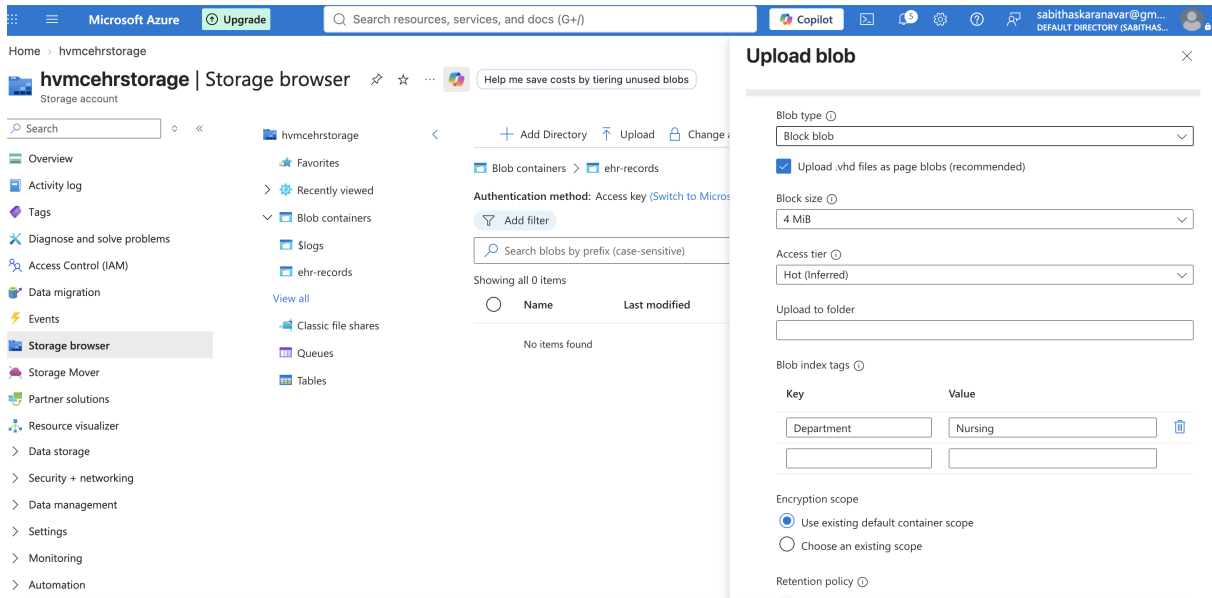


Figure 6.1 — Uploading nursing-note.txt with blob index tag Department: Nursing.

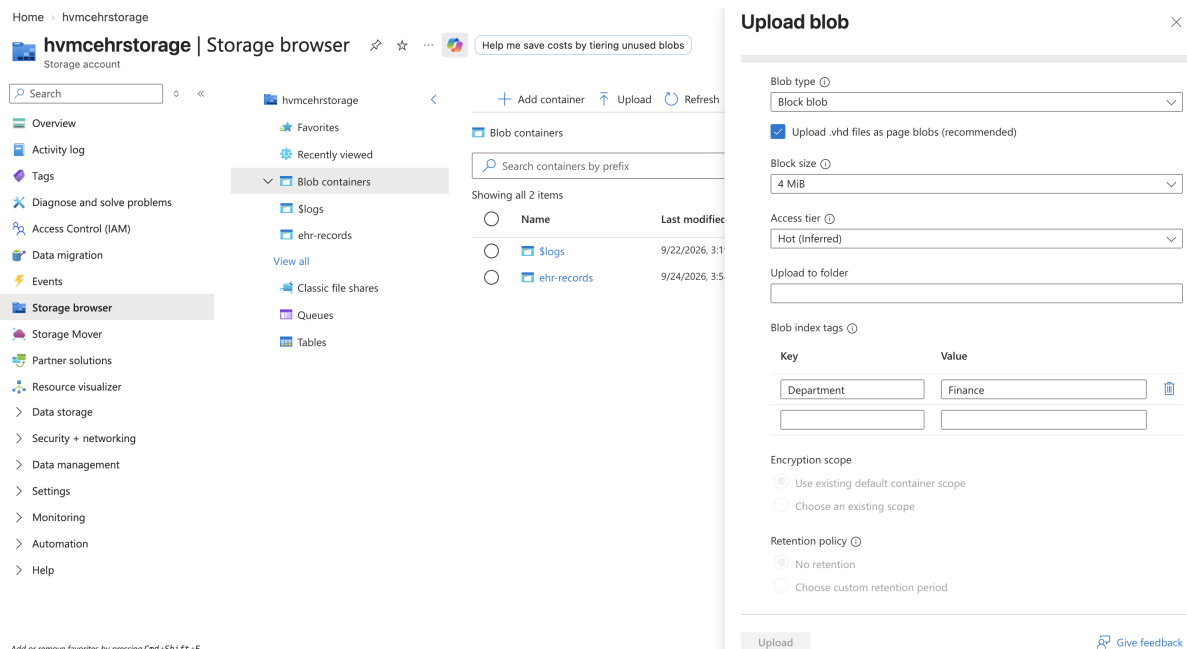


Figure 6.2 — Uploading finance-report.txt with blob index tag Department: Finance.

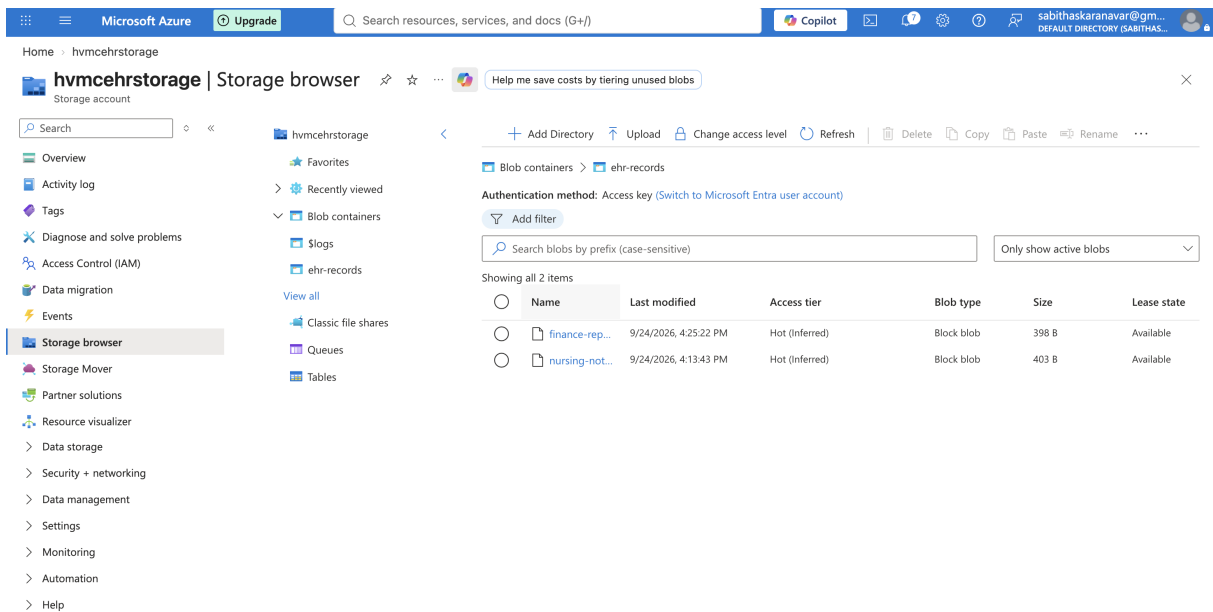


Figure 6.3 — Both tagged files present in the ehf-records container.

A **role assignment condition** was then attached to the HVMC-Nurse-EHR-ReadOnly role assignment for Test Nurse - EHR, restricted to the “Read a blob” data action. The condition expression checks the resource’s own Blob index tag: it evaluates to true only when the blob’s Department tag value equals “Nursing.”

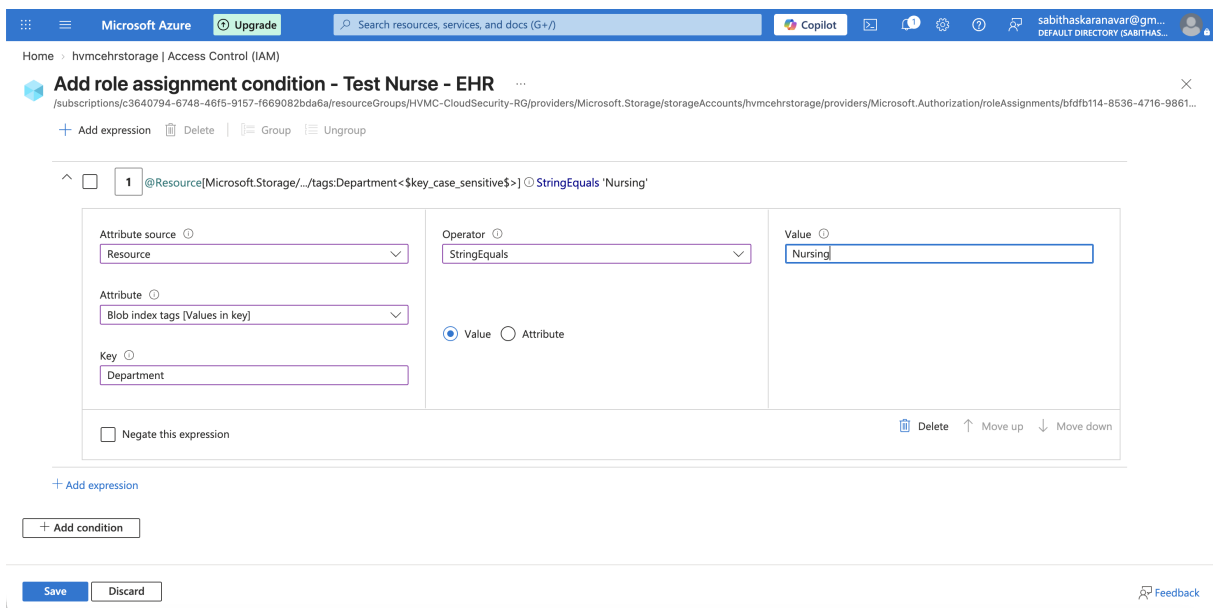


Figure 6.4 — ABAC condition expression: @Resource[...tags:Department] StringEquals 'Nursing'.

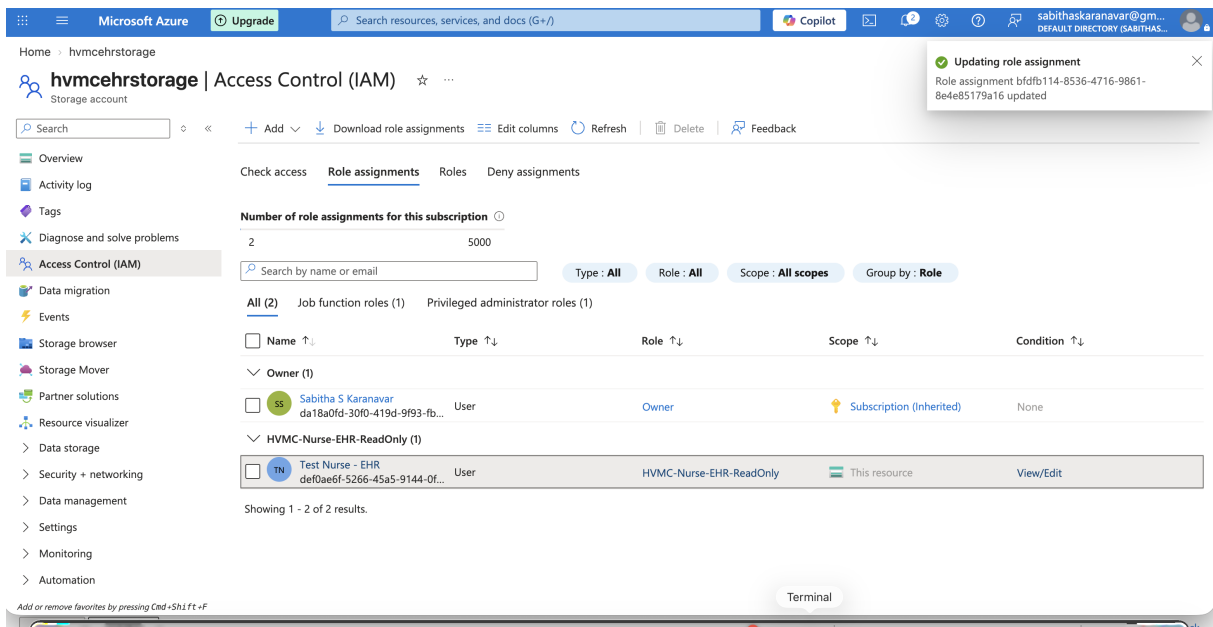


Figure 6.5 — Condition saved and attached to the HVMC-Nurse-EHR-ReadOnly role assignment (Condition column shows View/Edit).

6.1 — Enforcement test

Signed in as Test Nurse - EHR, the same role and the same container now produce two different outcomes purely based on each file's tag value:

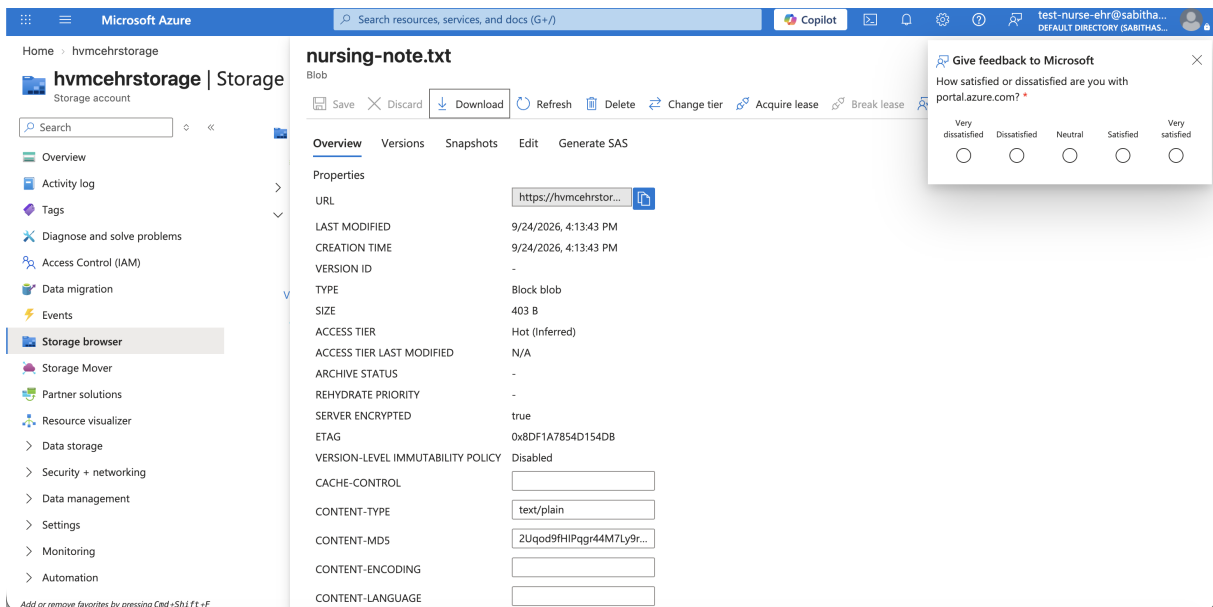


Figure 6.6 — ALLOWED: nursing-note.txt (Department: Nursing) opens successfully — tag matches the condition.

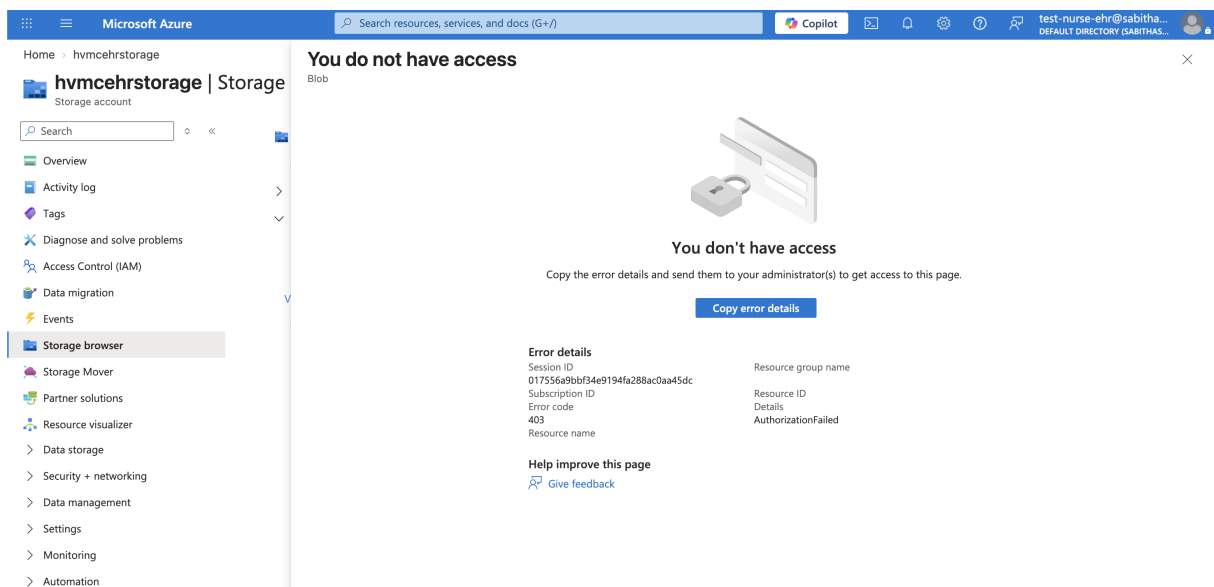


Figure 6.7 — DENIED: *finance-report.txt* (Department: *Finance*) returns 403 *AuthorizationFailed* — tag does not match.

This confirms the ABAC condition is actively enforced: access is no longer determined solely by role assignment, but dynamically by the resource's own attribute at request time.

7. Verification Testing: Read Allowed / Write Denied

Beyond the tag-based test above, baseline least-privilege enforcement was verified for the Test Nurse - EHR identity: read access to blob data succeeds, while any write, upload, or container-management action is denied.

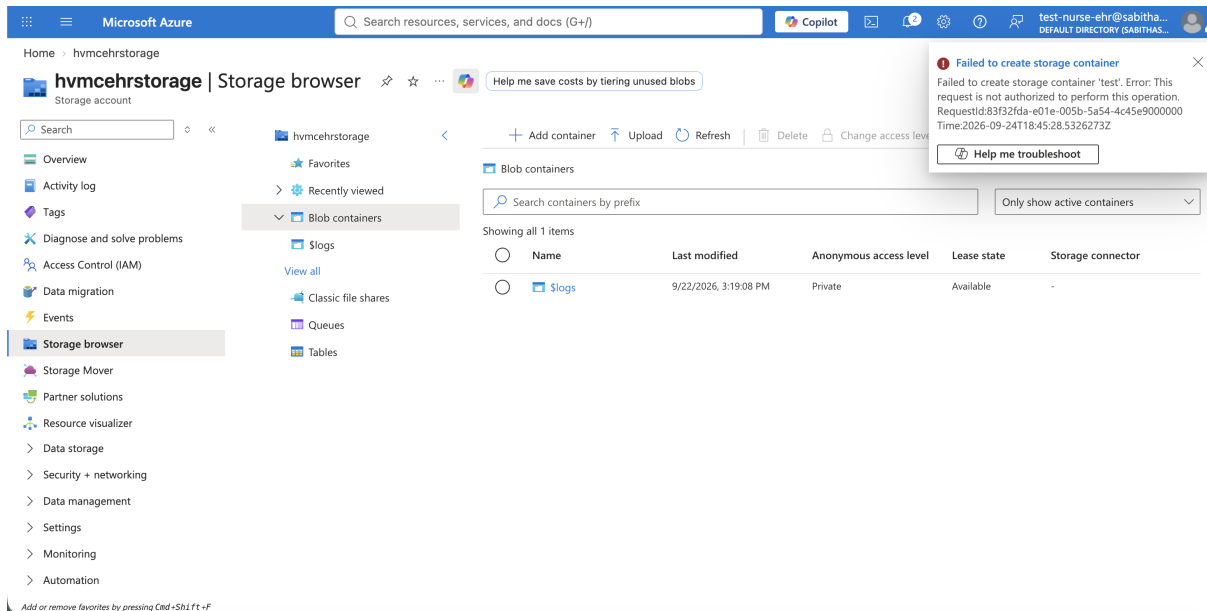


Figure 7.1 — Signed in as Test Nurse - EHR, attempting to create a new storage container fails with “This request is not authorized to perform this operation” — confirming no write/management permissions were granted.

Read access success is demonstrated in Figure 6.6 above (nursing-note.txt opened successfully as Test Nurse - EHR). Together, Figures 6.6 and 7.1 form the read-works / write-fails evidence pair required by the rubric.

8. Advanced: SAML Federation

Status: Not yet completed

SAML federation has not yet been configured or tested in this environment. This section documents the planned workflow and the specific constraint currently blocking full implementation, so that progress and next steps are transparent.

8.1 — Constraint

This tenant is running on the **Microsoft Entra ID Free** license tier. Free tier does not include Conditional Access policy creation and limits the ability to fully configure and test enterprise SAML application federation end-to-end (e.g., enforcing sign-in via a federated SAML app with policy-based controls). A Microsoft Entra ID P1/P2 license (or equivalent trial) would be required to complete this portion of the advanced rubric criteria in full.

8.2 — Planned Federation Workflow

1. Register a non-gallery Enterprise Application in Microsoft Entra ID to represent the federated Service Provider (SP) — e.g., a simulated HVMC clinical application.
2. Configure the application's Single Sign-On method as SAML, supplying the SP's Identifier (Entity ID) and Reply URL (Assertion Consumer Service URL).
3. Download the federation metadata / signing certificate from Microsoft Entra ID (acting as the Identity Provider, IdP) and configure it on the SP side.
4. Map user attributes and claims (e.g., name, email, role/department) from Entra ID into the SAML assertion sent to the SP.
5. Assign the Test Nurse - EHR identity to the new Enterprise Application so it is authorized to federate into it.
6. Perform an end-to-end authentication test: initiate sign-in at the SP, get redirected to Microsoft Entra ID for authentication (including MFA), and confirm a valid SAML assertion is returned and accepted by the SP.
7. Capture screenshots of each step above, plus the final successful SSO landing page, as evidence of a working federation workflow.

8.3 — Next Step

This remains the one open item on the IAM Implementation rubric's advanced tier. It will be completed either by provisioning a trial Entra ID P1 license to unlock full Conditional Access / federation testing, or by documenting a best-effort simulated workflow (application registration and metadata exchange only, without a live third-party SAML-consuming application) if a license upgrade is not available before the submission deadline.

9. Rubric Self-Assessment

The table below maps each rubric requirement to the section and figures that provide its evidence.

Requirement	Evidence	Status
Users, groups, roles with least privilege	Sections 2, 3, 5 (Fig. 2.1–2.2, 3.1, 5.3–5.6)	Complete
Multi-factor authentication	Section 4 (Fig. 4.1–4.2)	Complete
Screenshots throughout	All sections	Complete
Custom IAM policy using JSON	Section 5 (Fig. 5.1–5.5)	Complete
ABAC using resource tags	Section 6 (Fig. 6.1–6.7)	Complete
SAML federation + auth test evidence	Section 8	Not yet complete